DEEPGATE

Web Application Penetration Testing Report

Public-site assessment | 14 October 2026 | Report DG-WEB-2026-10-14

Prepared for the website owner. Prepared with Codex-assisted external testing. Confidential - owner review.

Executive assessment

The assessed public interfaces did not demonstrate SQL injection, authentication bypass, exposed configuration secrets, or database compromise. Server-side validation and CSRF rejection were observed. These results apply only to the sampled requests; they do not establish that all application queries, accounts, or database permissions are secure.

The highest-priority confirmed configuration issue is a session cookie issued without the Secure attribute, combined with absent HSTS on sampled HTTPS pages. This creates a conditional transport-exposure risk. No session interception or takeover was performed or demonstrated.

Severity	Confirmed findings
Critical / High	0 demonstrated
Medium	1 - cookie transport protection
Low	3 - CSP, password ceiling, HTTP resource URLs
Informational	2 - version disclosure, dependency governance

Ratings are qualitative and contextual, not calculated CVSS scores. Missing defenses are distinguished from demonstrated exploit chains. Overall residual risk remains unassessed because private features, backend configuration, and database privileges were unavailable.

Assessment depth

49 recorded public test cases: 24 SQL/input baseline and probe cases plus 25 extended HTTP checks. Crawl requests, CSRF preparation requests, a TLS handshake, and a separate three-request login attempt are additional and are not included in the 49-case count. No account creation, player-data changes, database extraction, denial-of-service, or time-delay SQL payloads were used.

A supplied account returned to the login page; authentication was not verified. The owner subsequently requested completion with public-site coverage. This report is complete for that agreed scope, not a full authenticated or infrastructure penetration test.

Scope, methodology and assurance limits

Item	Scope
Target	https://deepgate.site/ and sampled same-origin application routes
Test window	13-14 October 2026 UTC; extended HTTP checks on 14 October
Access model	Unauthenticated black-box testing; one unsuccessful supplied-account login
Allowed activity	Bounded crawl, static JavaScript review, non-destructive input probes, HTTP policy checks
Excluded systems	Third-party services, origin bypass, infrastructure scanning, game binaries/server internals, administrator features

Testing followed selected web-testing themes from OWASP WSTG, with targeted HTTP requests and evidence review. This is not a claim that every WSTG procedure was executed. REA was used for inert JavaScript analysis; it did not recover private backend source. Mr-Infect/AI-penetration-testing is reference material focused on AI/LLM systems, not a web scanner. No public AI integration was identified in the inspected material.

Control area	Coverage	Outcome / limitation
Public attack surface	Sampled	Crawled pages, four ranking categories, public player/guild routes and status endpoints.
SQL injection	Partial	Quote/boolean probes; no demonstrated injection. No blind time tests or query-source verification.
Authentication	Partial	Synthetic failures and validation; supplied account not verified.
CSRF	Sampled	Missing token rejected on three forms; invalid login token rejected.
Session / transport	Partial	Cookie flags, redirect and one TLS handshake. Login rotation and logout not verified.
CORS / headers	Sampled	One untrusted Origin on two GET routes and one preflight.
File exposure / errors	Sampled	Five sensitive-file paths denied; one debug endpoint absent.
XSS / browser output	Static only	Read first-party scripts. No full reflected/stored XSS or browser execution assessment.
Authorization / game logic	Not tested	Requires authenticated accounts, roles, and representative workflows.
Database / infrastructure	Not tested	No database grants, firewall, backups, server or source access.

The initial 12-URL crawl retrieved three linked patch archives in addition to HTML pages. They were not executed or analyzed. All subsequent testing remained targeted; no subdomain sweep or unrestricted route brute force was performed.

F-01 | Session cookie transport protection

Severity: MEDIUM | Confidence: HIGH for configuration, conditional for exploitation | Status: OPEN

Affected surface

HTTPS home, login, registration, and password-recovery responses. Evidence: EXT-01 to EXT-05; repeated cookie observations on other sampled responses.

Observed evidence

The application issues copoker_session with HttpOnly and SameSite=Strict, but without Secure. XSRF-TOKEN also lacks Secure. Strict-Transport-Security was absent on the four sampled HTTPS pages. A direct HTTP request returned 301 to HTTPS.

```
Set-Cookie: copoker_session=[REDACTED]; Max-Age=7200; path=/; HttpOnly; SameSite=Strict
Secure: absent
Strict-Transport-Security: absent
GET http://deepgate.site/ -> 301 Location: https://deepgate.site/
```

Risk and boundaries

A cookie without Secure may be attached to an HTTP request before the server returns its redirect. Where an attacker can influence or observe a plaintext request and the browser lacks an applicable HSTS policy, session material can be exposed. HttpOnly and SameSite do not enforce HTTPS transport. The assessment did not verify whether this domain is covered by an existing browser/preload HSTS policy, and it did not capture any user session in transit. Authenticated cookie flags remain unverified.

Reproduction

1. Request https://deepgate.site/login and inspect cookie attributes without sharing cookie values.
2. Confirm copoker_session lacks Secure and the HTTPS response lacks HSTS.
3. Request the HTTP root separately and observe the HTTPS redirect. A redirect alone does not prevent cookies being sent in the initial request.

Remediation

Configure the application to issue session cookies with Secure=true. If TLS terminates at Cloudflare or another proxy, verify trusted-proxy and HTTPS detection settings. Retain HttpOnly on the session cookie and a suitable SameSite policy. The readable XSRF token is not itself an HttpOnly finding. Deploy HSTS on HTTPS after validating all affected hosts; stage max-age before considering includeSubDomains or preload. Reference R2.

Retest acceptance

Fresh pre-login and authenticated session cookies include Secure; HTTP never serves application content; HTTPS responses carry the intended HSTS policy; login, logout and existing player clients still work. Do not infer session-ID rotation solely from changed encrypted cookie bytes.

F-02 | No enforced Content Security Policy

Severity: LOW | Confidence: HIGH for sampled pages | Status: OPEN

Evidence: EXT-01 to EXT-04 and captured HTML. Content-Security-Policy was absent from response headers, and no CSP meta policy was identified in the sampled captured homepage. The site uses inline and third-party scripts. X-Frame-Options: SAMEORIGIN and X-Content-Type-Options: nosniff were present.

Impact: the sampled pages lack CSP as a second layer to limit script execution if an injection or asset compromise occurs. Missing CSP does not prove XSS and does not independently expose the database.

Remediation: inventory required script/style/connect origins and deploy a nonce- or hash-based policy appropriate to the application. Use report-only telemetry during rollout, then enforce a tested policy. Avoid treating a broad unsafe-inline or wildcard policy as a complete fix. Account for inline status/event code and external fonts, icons and scripts. Reference R3.

Retest: verify an enforced policy on HTML responses and confirm legitimate account forms and page assets function without unexpected violations.

F-03 | Restrictive password-length ceiling

Severity: LOW | Confidence: HIGH for advertised limit and rejection test | Status: OPEN

Evidence: login and registration markup advertises minlength=6 and maxlength=14; first-party password-validation JavaScript also uses a 6-14 range. EXT-25 submitted a 15-character synthetic password with a fresh CSRF token and received HTTP 422. No real account password was changed.

Impact: a 14-character ceiling prevents longer passphrases. The observed six-character minimum is a policy concern; successful registration at that minimum was not tested. Password hashing, MFA, breached-password screening and game-client limitations remain unknown. No password cracking or account takeover was demonstrated.

Remediation: review the shared website/game authentication design before changing limits. Support longer passwords where the entire stack can handle them safely, avoid silent truncation, and use a modern password-storage scheme. OWASP recommends permitting a maximum length of at least 64 characters. If the game protocol has a strict limit, document it and plan a compatible authentication upgrade with compensating protections. Reference R4.

Retest: validate supported lengths end to end using disposable accounts; verify the website and game client agree and do not truncate credentials.

F-04 | HTTP resource URLs in HTTPS pages

Severity: LOW | Confidence: HIGH for source; runtime impact unverified | Status: OPEN

Evidence: captured homepage line 116 specifies an HTTP video poster; line 234 supplies an HTTP event URL; line 468 fetches the online-status endpoint over HTTP. REA independently identified the literal online endpoint in JavaScript.

```
http://deepgate.site/assets/deepgate/jade-gate.png
http://deepgate.site/server/events
http://deepgate.site/server/online
```

Impact: HTTP resources from an HTTPS document can be blocked or upgraded by browsers, causing stale status displays or asset failures. Where plaintext fetches occur, their content lacks transport integrity. Browser console verification could not be completed because the browser view failed to attach, so no claim is made that a specific browser actually sent these requests over HTTP.

Remediation: generate HTTPS or same-origin relative URLs for all page resources. Correct application URL/proxy configuration and cached templates as needed. Retest using browser network and console panels on home, ranking and account pages.

O-01 | Runtime version disclosure

Informational. EXT-01 to EXT-04 advertise X-Powered-By: PHP/8.2.12. This supports technology fingerprinting, but a banner does not establish the installed patch state or a specific exploitable vulnerability. Remove unnecessary version disclosure and have the owner verify runtime security updates against the actual deployment. No CVE or unsupported-version claim is made.

O-02 | Third-party script governance

Informational. The captured page references jQuery 3.5.1 and https://unpkg.com/sweetalert/dist/sweetalert.min.js. The SweetAlert URL is not version pinned and the observed external script tags lack integrity attributes. No compromised dependency or exploitable library defect was demonstrated; third-party source and a dependency lockfile were not assessed.

Pin and review external dependencies, self-host vetted copies where practical, and consider Subresource Integrity for immutable cross-origin resources. Validate compatibility before library upgrades. This is an asset-governance recommendation, not evidence of malicious code.

Verification results and positive controls

Test group	Observed result	Assurance boundary
Login usernames	Quote and true/false inputs: 422 format errors.	Server validation observed; query implementation unknown.
Login passwords	Baseline and true/false strings: matching 302 redirects to login.	Synthetic nonexistent usernames; not proof of all password paths.
Registration	Username and numeric field validation errors; email quote produced no SQL error.	CAPTCHA/rules absent and passwords mismatched; successful insertion untested.
Recovery	Synthetic name redirects; quote-containing name: 422.	Valid reset delivery, token lifetime and reuse not tested.
Guild / player route	Malformed numeric IDs and modified opaque token: 404.	No true/false difference; backend lookup unknown.
CSRF	EXT-18/20/22: missing token 419. EXT-23: invalid login token 419.	Sampled forms only; no authenticated actions tested.
CORS	EXT-14/15/16: no Access-Control-Allow-Origin for untrusted Origin.	No permissive grant observed for those routes/origin.
Sensitive paths	/.env, /.git/HEAD, composer files, Laravel log: 403.	Public route denial only; files may still exist on origin.
Debug / errors	Ignition health route: 404; no sampled SQL/stack-error marker.	Not an exhaustive debug-route or error assessment.
TLS / HTTP	Certificate validation passed; TLS 1.3 negotiated; HTTP root redirects.	One client/handshake, not a protocol/cipher or origin-server audit.

The observed session cookie is HttpOnly and SameSite=Strict. HTML responses have nosniff, SAMEORIGIN, a referrer policy, and restrictive camera/microphone/geolocation permissions. EXT-25 advertised an eight-request rate limit and EXT-15 a thirty-request limit. These headers were observed; thresholds, reset windows and bypass resistance were not exercised.

Supplied-account attempt: AUTH-01 to AUTH-03 loaded login, submitted credentials once, and returned to /login. No authenticated page or private player record was accessed. Credentials and cookie values are omitted from evidence deliverables. The unsuccessful attempt is not classified as an application vulnerability.

Remediation plan and completion criteria

Priority	Owner action	Verification
First	F-01: enable Secure session cookies; validate HTTPS/proxy handling; stage HSTS.	Inspect fresh cookies before and after login; verify HTTPS enforcement without breaking clients.
Next	F-04: replace HTTP resource URLs with HTTPS/relative URLs.	Browser network/console shows correct same-origin HTTPS requests.
Next	F-02: inventory asset origins and roll out a tested CSP.	Report-only observations reviewed; enforced policy tested across workflows.
Planned	F-03: assess website/game password compatibility and modernize policy.	Long passwords work end to end or documented limitations are mitigated.
Routine	O-01/O-02: reduce version disclosure and control dependency versions.	Actual versions inventoried, patch review completed, pinned assets verified.

What remains before a full application assessment

Two disposable player accounts and an equivalent staging environment are needed to test cross-account access, account linking, stored inputs and authenticated game-account workflows. Relevant roles are needed for administrator authorization checks. A test CAPTCHA configuration allows successful registration testing without bypassing live controls.

Remaining work includes authenticated SQL/XSS tests; second-order and carefully bounded blind SQL tests in staging; reset-token reuse and expiry; session fixation, logout invalidation and concurrent sessions; account enumeration using known test accounts; mass assignment; balance/purchase tampering using synthetic transactions; upload handling if present; and logging/alert verification with the owner.

Infrastructure and database assurance require separate evidence about origin exposure, network rules, backups, database privileges, parameterized query use and password storage. These properties cannot be established from public HTTP responses alone. Backend source is optional for black-box testing, but owner-side configuration review is still needed for those internal controls.

Database-risk conclusion

No evidence obtained in this scope shows that an attacker can dump the database. There is also insufficient evidence to exclude that possibility across untested routes and internal configuration. Retain parameterized queries and least-privilege database access; do not rely on username filtering or Cloudflare as substitutes. Reference R5.

This edition records public-site coverage as requested by the owner after the supplied-account login could not be verified. It is not a compliance certification, a guarantee of security, or a report of completed authenticated testing.

Appendix A | SQL and input case ledger

SQL-01 to SQL-24. Status codes are observations, not pass/fail certifications. Detailed validation messages and test strings are in the sanitized JSON evidence. Public player tokens are redacted.

ID	Route / input surface	Case	Result
SQL-01	/ranking/players	public route baseline	200
SQL-02	/ranking/vip	public route baseline	200
SQL-03	/ranking/nobility	public route baseline	200
SQL-04	/ranking/guild	public route baseline	200
SQL-05	/guild/1001	public route baseline	200
SQL-06	/server/online	public route baseline	200
SQL-07	/guild/1001%27	guild id probe	404
SQL-08	/guild/1001%20AND%201%3D1	guild id probe	404
SQL-09	/guild/1001%20AND%201%3D2	guild id probe	404
SQL-10	/player/{token}	player token quote	404
SQL-11	/loginAccount	login input probe	302 -> login
SQL-12	/loginAccount	login input probe	422 validation
SQL-13	/loginAccount	login input probe	422 validation
SQL-14	/loginAccount	login input probe	422 validation
SQL-15	/register	registration validation probe	422 validation
SQL-16	/register	registration validation probe	422 validation
SQL-17	/register	registration validation probe	422 validation
SQL-18	/register	registration validation probe	422 validation
SQL-19	/forgot-password	recovery input probe	302 -> form
SQL-20	/forgot-password	recovery input probe	422 validation
SQL-21	/loginAccount	login password probe	302 -> login
SQL-22	/loginAccount	login password probe	302 -> login
SQL-23	/loginAccount	login password probe	302 -> login
SQL-24	/server/events	events public baseline	200

No SQL error markers were observed. No successful authentication or database extraction was demonstrated. Timings were recorded for context; no time-based inference or sleep payload was used. The case count includes baseline requests.

Appendix B | Extended HTTP case ledger

ID	Method / path	Case	Status
EXT-01	GET /	Headers/cookies	200
EXT-02	GET /login	Headers/cookies	200
EXT-03	GET /register	Headers/cookies	200
EXT-04	GET /forgot-password	Headers/cookies	200
EXT-05	GET http://deepgate.site/	HTTP redirect	301
EXT-06	GET /.env	Environment file denied	403
EXT-07	GET /.git/HEAD	Git metadata denied	403
EXT-08	GET /composer.json	Composer manifest denied	403
EXT-09	GET /composer.lock	Composer lock denied	403
EXT-10	GET /storage/logs/laravel.log	Application log denied	403
EXT-11	GET /_ignition/health-check	Debug route absent	404
EXT-12	GET /robots.txt	Robots metadata	200
EXT-13	GET /sitemap.xml	Sitemap absent	404
EXT-14	GET /login	Untrusted Origin GET	200
EXT-15	GET /server/online	Untrusted Origin GET	200
EXT-16	OPTIONS /loginAccount	CORS preflight	200
EXT-17	GET /login	CSRF preparation	200
EXT-18	POST /loginAccount	No CSRF token	419
EXT-19	GET /register	CSRF preparation	200
EXT-20	POST /register	No CSRF token	419
EXT-21	GET /forgot-password	CSRF preparation	200
EXT-22	POST /forgot-password	No CSRF token	419
EXT-23	POST /loginAccount	Invalid CSRF token	419
EXT-24	GET /login	Password-test preparation	200
EXT-25	POST /loginAccount	15-character password	422

Account attempt: AUTH-01 GET /login -> 200; AUTH-02 POST /loginAccount -> 302 /login; AUTH-03 GET /login -> 200. No authenticated session was verified. No further credential attempts were performed after the owner selected public coverage.

TLS observation: TLSv1.3 / TLS_AES_256_GCM_SHA384. Hostname and trust-chain validation passed for that connection. Certificate validity reported: Sep 20 09:04:29 2026 GMT to Dec 19 09:04:28 2026 GMT.

Appendix C | Evidence and references

Evidence collection retained request outcomes, cookie attributes with values removed, relevant response headers, validation errors, timings and REA graph summary. Credentials, session values, CSRF tokens and real private player records are not included in the deliverables. No packet capture of other users was performed.

Deliverable	Purpose
deepgate-penetration-testing-report.pdf	Shareable report, findings, limits and remediation.
deepgate-penetration-testing-report.md	Editable report text and tables.
deepgate-assessment-evidence.json	Sanitized case-level evidence and tool summary.

```
Evidence JSON SHA-256:
ae8338058d19d93584c828e59cd971bbffe54f894c15fce37f4f8d67430fc999
```

```
REA evidence ID:
ev_85ab1d9dbd6c05c2702dbf91d1d9622bfe561a4d28269b69ec661681ab0ac0fe
```

REA 6.4.0 analyzed retrieved first-party JavaScript as inert text. Its recorded summary includes 21 JavaScript modules, five asset identities, two storage nodes and one literal endpoint node. Static graph counts are not vulnerability counts. Public URLs and encrypted profile identifiers do not expose underlying server SQL. The complete large REA evidence and raw crawl intermediates remain local, outside the deliverable evidence bundle.

References

R1 | OWASP Web Security Testing Guide
https://owasp.org/www-project-web-security-testing-guide/stable/

R2 | OWASP Session Management Cheat Sheet
https://cheatsheetseries.owasp.org/cheatsheets/Session_Management_Cheat_Sheet.html

R3 | OWASP Content Security Policy Cheat Sheet
https://cheatsheetseries.owasp.org/cheatsheets/Content_Security_Policy_Cheat_Sheet.html

R4 | OWASP Authentication Cheat Sheet
https://cheatsheetseries.owasp.org/cheatsheets/Authentication_Cheat_Sheet.html

R5 | OWASP SQL Injection Prevention Cheat Sheet
https://cheatsheetseries.owasp.org/cheatsheets/SQL_Injection_Prevention_Cheat_Sheet.html

R6 | REA repository / browser and CLI documentation
https://github.com/morluto/rea

R7 | AI/LLM penetration-testing reference repository
https://github.com/Mr-Infect/AI-penetration-testing

Source guidance was consulted on 14 October 2026. Technical recommendations are scoped to the observed configuration and require application-owner validation before deployment. No changes were deployed to the website.